

Information Security Management System (ISMS) Scope Statement

GRC Practicum - Project 5 | NOVAtech Inc. (simulated scenario) | Aligned to ISO/IEC 27001:2022 Clause 4.3

Note: NOVAtech Inc. is a fictional company; this scope statement is simulated for demonstration. The structure and content reflect real-world ISO 27001 scope documentation.

Document	ISMS Scope Statement
Version	1.0
Approved by	Chief Technology Officer
Effective date	[date of approval]
Next review	Annually or on significant business change
Related documents	Statement of Applicability, Information Security Policy, Asset Inventory (Project 4A), Risk Register (Project 2)

1. PURPOSE

This document establishes the scope of NOVAtech's Information Security Management System (ISMS) in accordance with ISO/IEC 27001:2022 Clause 4.3. The scope defines the organizational, geographic, and technological boundaries within which the ISMS operates, and identifies interested parties whose requirements the ISMS is designed to address.

2. ORGANIZATIONAL CONTEXT

NOVAtech Inc. is a 200-person Canadian business-to-business software-as-a-service (SaaS) company headquartered in Edmonton, Alberta. The company hosts customer data in AWS ca-central-1 and operates a remote-first workforce distributed across Canada. Growth strategy is enterprise expansion in North America first, followed by international deals in years 2 and 3 (per the framework selection memo, Project 4B).

Internal issues considered (per Clause 4.1): remote-first operating model, cloud-native infrastructure, small dedicated security function, growth pressure on control maturity. External issues considered: enterprise buyer expectations (SOC 2, ISO 27001), PIPEDA and provincial privacy law obligations, evolving threat landscape targeting SaaS providers, and dependency on major cloud providers.

3. INTERESTED PARTIES (CLAUSE 4.2)

- **Customers:** contractual security commitments in MSAs and DPAs; SOC 2 report requests during procurement; incident notification expectations
- **Office of the Privacy Commissioner of Canada (OPC):** PIPEDA compliance; breach reporting if RROSH is met; records retention 24 months
- **Provincial privacy regulators:** Quebec's Commission d'accès à l'information (CAI) under Law 25 if Quebec data subjects; Alberta OIPC under PIPA
- **Employees and contractors:** protection of personal data (HR, payroll); confidence in workplace systems; awareness training obligations
- **Third-party vendors:** contractual data protection obligations flow both ways; Tier-1 vendors under formal TPRM
- **Investors and executive leadership:** risk visibility, incident transparency, and compliance readiness for future funding and enterprise deals

4. SCOPE BOUNDARIES

4.1 Products and services in scope

The NOVAtech customer platform, including the production application, its APIs, and all supporting infrastructure. Also in scope: the corporate IT services that support development, operation, and support of the customer platform.

4.2 Locations in scope

- AWS ca-central-1 - production hosting of the customer platform, databases, and supporting services
- Microsoft cloud (Canadian regions) - Microsoft 365 tenant serving all staff (email, collaboration)

- Okta cloud - single sign-on and identity provider
- Edmonton, Alberta HQ facility - corporate IT services, no production systems
- Distributed remote workforce across Canada - endpoints managed via MDM

4.3 Business functions in scope

Engineering, Security Operations, IT, Product, Customer Support, and the GRC function itself.

4.4 Explicitly excluded from scope

The following are formally excluded from the ISMS, with documented rationale:

- **Marketing function and marketing website (asset A-23):** hosts only public content; no personal or customer data; separate infrastructure (Vercel); no operational dependency for the customer platform. Included in ISMS could create scope creep without corresponding security benefit.
- **Physical security of employee home offices:** addressed through endpoint controls (MDM, full-disk encryption, EDR, secure authentication) rather than premise controls. Home office physical premises are outside the organization's direct control.

5. INTERFACES AND DEPENDENCIES

The ISMS operates within an ecosystem of external services under shared-responsibility models. Key interfaces:

- **AWS:** IaaS provider; NOVAtch responsible for identity, data, application, network configuration within the tenancy; AWS responsible for physical and infrastructure-layer controls
- **Microsoft 365 and Okta:** SaaS providers; NOVAtch responsible for tenant configuration, identity, and data handling; providers responsible for platform security
- **Stripe (payment processing):** tokenization keeps card data out of NOVAtch systems; PCI DSS scope reduction achieved via tokenization architecture
- **PayCo (payroll SaaS):** Tier-1 vendor handling employee restricted data; formal TPRM assessment (Project 9); DPA in place with breach notification requirements
- **Salesforce (CRM), GitHub (source control):** Confidential and IP data respectively; SSO integration; monitoring for data-egress patterns

6. APPLICABILITY OF ISMS REQUIREMENTS

All requirements of ISO/IEC 27001:2022 Clauses 4 through 10 apply within this scope. Selection of Annex A controls is documented in the Statement of Applicability (Project 5B), which identifies applicable controls with justifications and evidence expectations. One control (A.7.4 Physical security monitoring) is documented as Not Applicable because no production systems reside at HQ; this exclusion is defended in the SoA and linked to accepted risk R-15.

7. GOVERNANCE

- **Accountable executive:** Chief Technology Officer (owns Information Security Policy per Clause 5.2)
- **Operational owner:** Head of Security / GRC lead
- **Scope review:** annually and on significant business change (major product launches, geographic expansion, material acquisitions, workforce restructuring)
- **Scope amendment:** proposed by GRC, approved by CTO, communicated to all interested parties

8. CHANGE HISTORY

v1.0 (initial issue): baseline scope covering the NOVAtch customer platform and supporting corporate IT services. Excludes marketing function and home office physical security with documented justification.

THE STRUCTURE - REUSABLE SKELETON

What job each section of a scope statement does. Apply this same anatomy to any ISMS scope document.

- **Purpose (tie to Clause 4.3):** names the standard and clause the scope satisfies. Auditors verify scope against the clause, so cite it explicitly.

- **Organizational context (Clause 4.1):** the business you actually are, not the business you wish you were. Growth stage, workforce shape, geography, technology stack. Frames every subsequent decision.
- **Interested parties (Clause 4.2):** who cares that this ISMS exists, and what do they need? This section is where compliance obligations become concrete.
- **Boundaries (positive):** the assets, locations, functions IN scope. Should trace directly to the asset inventory - if it is not in the inventory, it cannot be in scope.
- **Boundaries (negative):** the exclusions with JUSTIFICATION. A scope without exclusions is either unreviewed or overreaching. Every 'excluded' item must survive an auditor asking why.
- **Interfaces:** shared-responsibility declarations. Modern ISMS scopes touch cloud providers; naming the boundary at each interface prevents scope disputes during audit.
- **Governance:** who owns the scope, how it changes, how often it is reviewed. Anything without an owner does not exist.